



The other AI: Assets and Identity. Using Splunk to keep in check

SEC1053

David Pollard
Unshakeable Salt Ltd, @UnshakeableSalt

The other AI: Assets and Identity. Using Splunk to keep in check

Compliance doesn't have to be a checkbox chase. Splunk can transform governance into a living, automated process—mapping assets, identities, and risks in real time.

Learn how to align with the UK Government's Cyber Assessment Framework & the NIST Cyber Security Framework while leveraging AI-driven, agentic workflows to detect anomalies, trigger automated responses, and sustain a continuously monitored, audit-ready environment powered by Splunk Enterprise and Splunk Enterprise Security.



Takeaway #1

Learn how to use Splunk for continuous asset discovery and risk tracking across secure infrastructures.



Takeaway #2

How Splunk's automated governance workflows simplify meeting regulatory mandates such as the Cyber Assessment Framework / NIST Cyber Security Framework



Takeaway #3

Understand how to turn compliance reports into proactive, automated security actions inside Splunk.



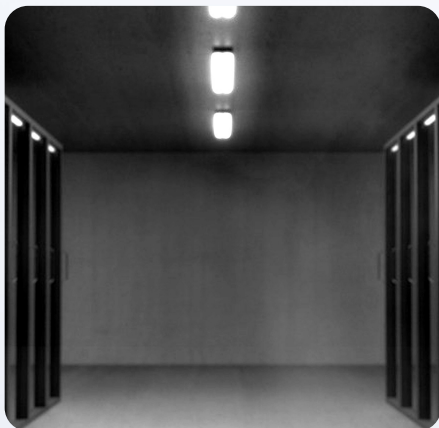
**You can't protect what you don't
know you have.**

Dave DeWalt

Former CEO, McAfee & FireEye · Founder, NightDragon

Defining Terms

...because you really can't guess how much is debated



Asset

any component of the technical estate that must be identified, tracked, and secured - physical hardware, VMs, cloud instances, containers, code repositories, SaaS/third-party services.
Not just servers and laptops.



Identity

any entity - human or non-human - that authenticates and is granted access:
users, service accounts, workload identities
Agentic AI Agents

**Most orgs don't have
a CMDB. The ones
that do don't trust it.**

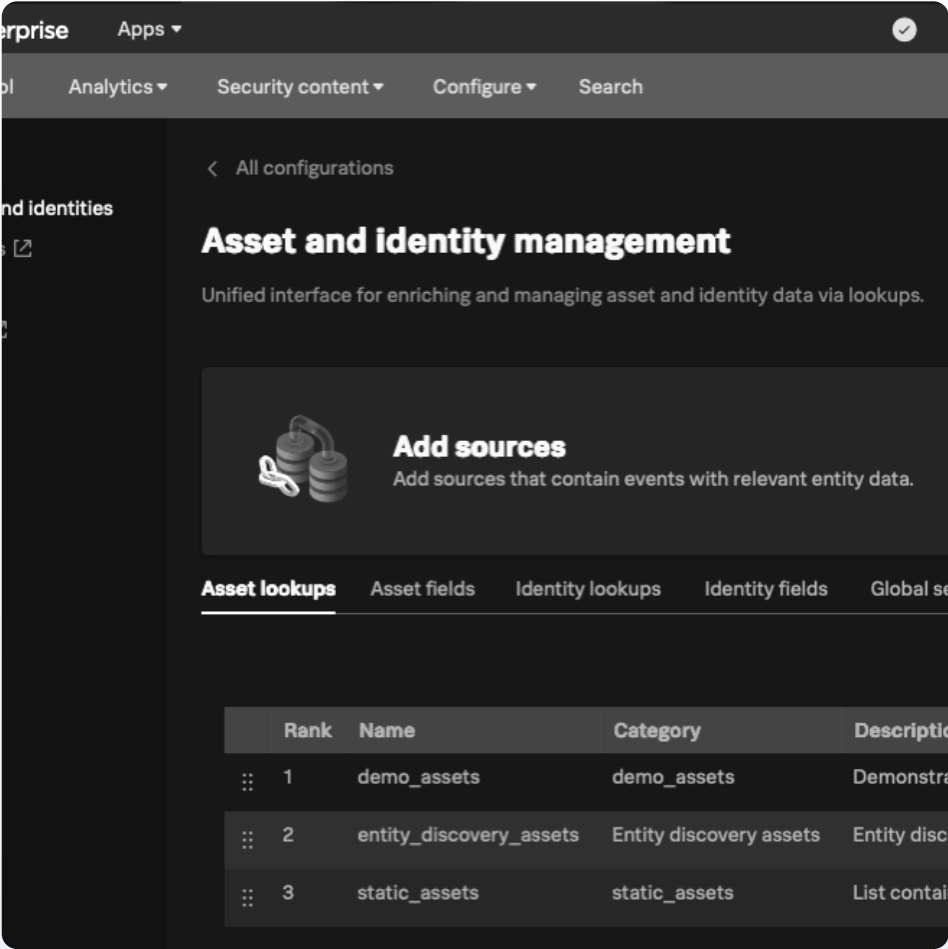
Reality Check

Why CMDBs Fail (Even When They Exist)

- Manual entry drift,
- M&A sprawl
- shadow IT
- ephemeral cloud instances
- ownership silos.

The CMDB is a snapshot;
your environment is a
stream.

Reframe: ES Isn't a CMDB Replacement, It's an Enrichment Layer



"The SOC Missed the Alert"

Everyone always, without mentioning;

- there was no telemetry source
- the forgotten storage bucket
- the still-routable decommissioned VPN concentrator
- the admin account nobody remembered existed

The Data You Don't Have

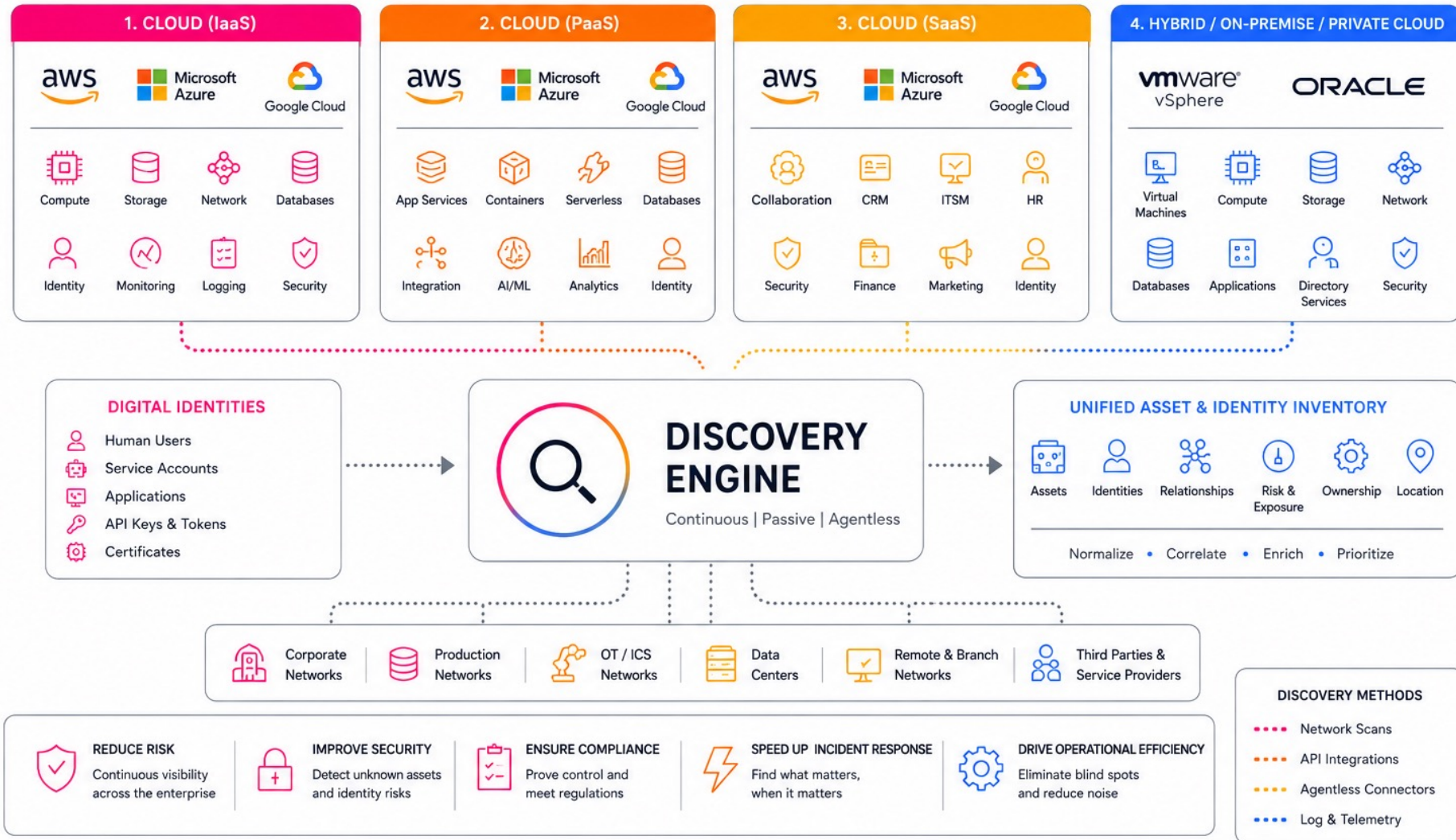
(And Why That's Why Enterprise Security Fails)

- unmanaged BYOD
- shadow IT
- SaaS nobody provisioned through IT
- decommissioned-but-still-live cloud resources nobody tore down
- OT/IoT devices with no agent capability
- contractor/third-party laptops
- orphaned service accounts
- undocumented API integrations
- pre-EDR-rollout assets
- M&A-inherited environments never fully onboarded
- AI Agents
- Github Repos
- MCP Servers

An unmonitored asset isn't a "known unknown" on a risk register — it's genuinely invisible. Your SIEM, EDR, and vulnerability scanner are only as good as their coverage; nothing analyses telemetry that was never generated

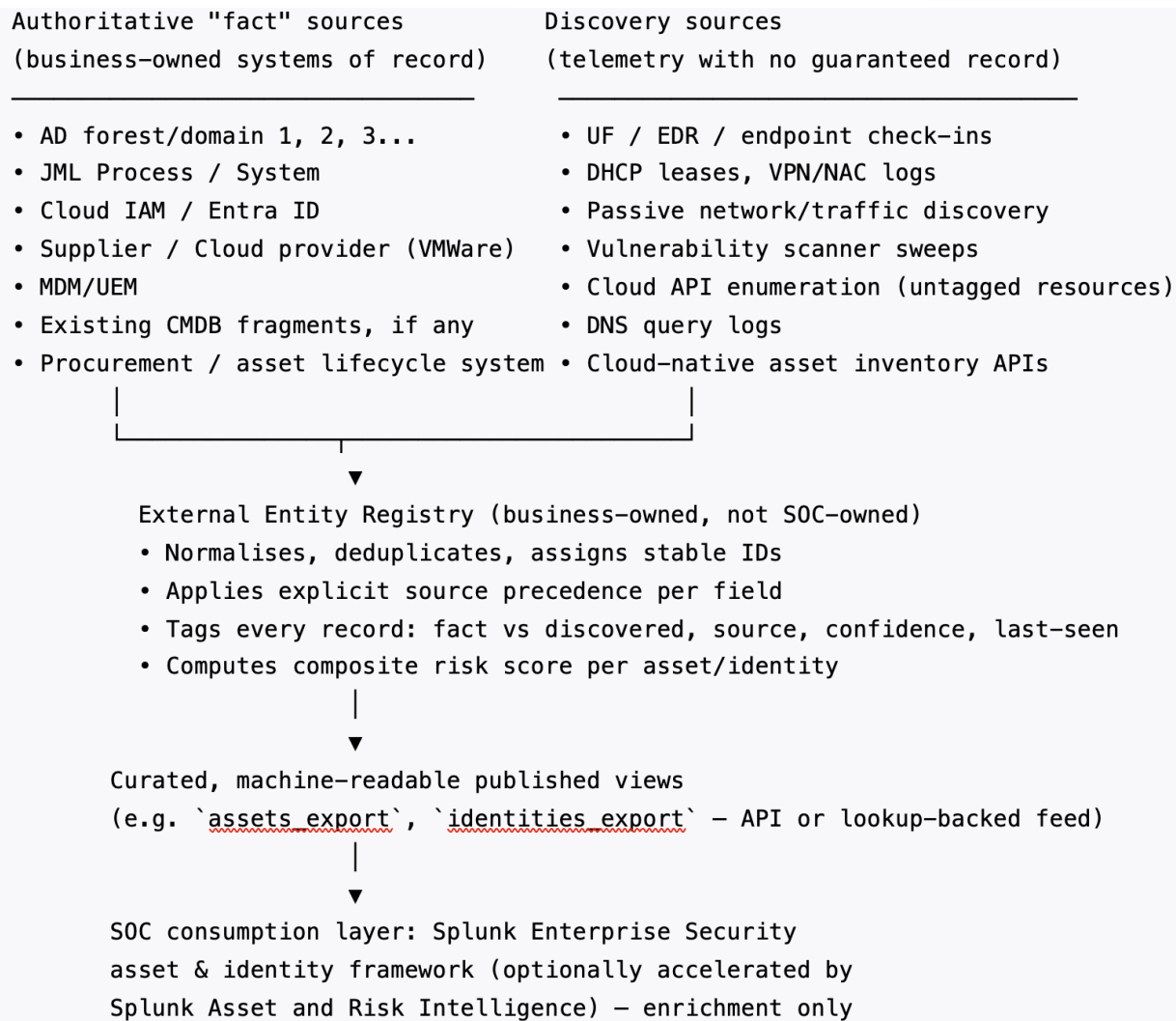
ACROSS A COMPLEX ENTERPRISE

One view. Every asset. Every identity. Every connection.

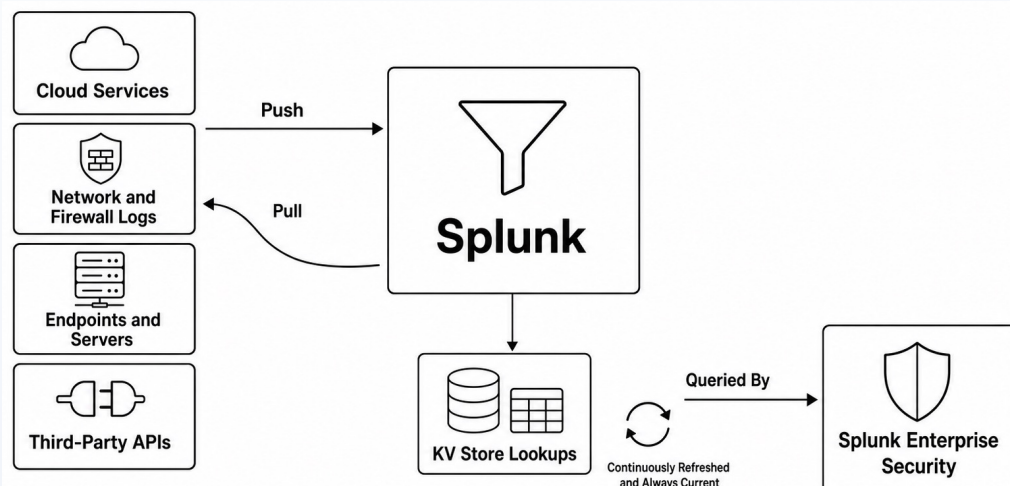
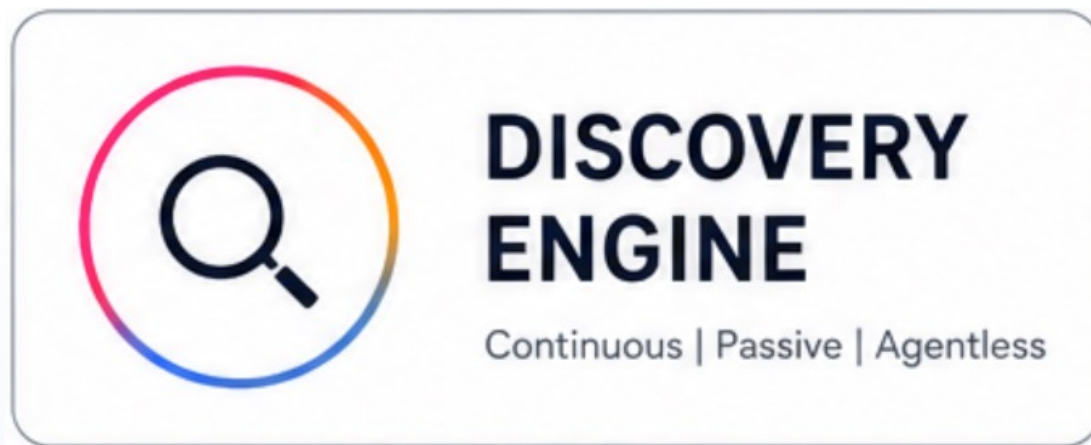


SOC is a consumer, not the custodian	The SOC never becomes the team people email to "get the asset list updated." It receives a governed, machine-readable feed and raises data-quality exceptions back to the business owner — it does not fix the data itself except as a logged, time-boxed emergency override.
No spreadsheets in the SOC	If a SOC analyst's working reference for an asset or identity is a spreadsheet, document, or wiki table, the design has failed. Everything the SOC touches must be structured (JSON/lookup/API/KV Store), versioned, and automatically refreshed.
One authoritative owner per attribute, many consumers	Different systems legitimately own different fields — HR owns employment status, a given AD domain owns its own computer objects and group membership, cloud tagging policy owns environment/owner tags. Downstream systems, including the SOC's tooling, are controlled consumers of that record, never a second master.
Facts and discoveries are treated differently	A record asserted by a designated authoritative source is a <i>fact</i> . A record surfaced only by telemetry, with no corroborating authoritative source, is <i>discovered</i> and carries lower confidence until it is claimed or reconciled.
Every entity carries a live confidence and risk score	Never mix "we are sure this is accurate" with "this is dangerous" — track them as two separate, continuously recalculated scores per asset and per identity.

Target Architecture



Building the "Poor Man's CMDB" in Splunk



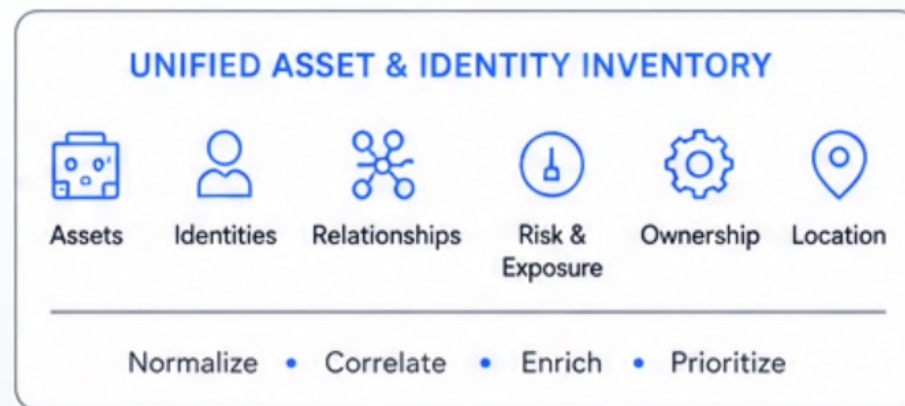
```
`` Correlate network/auth activity against Asset and Identity inventories ``
index=network_traffic OR index=auth OR
index=osquery
| eval asset_id=coalesce(dest_asset_id, dvc, dest)
| eval identity_id=coalesce(user, service_account, workload_identity)

`` Enrich with Asset inventory (KV Store-backed lookup, refreshed every 15m) ``
| lookup asset_inventory_lookup asset_id
  OUTPUT asset_owner, asset_type,
  asset_environment, asset_criticality,
  asset_last_seen

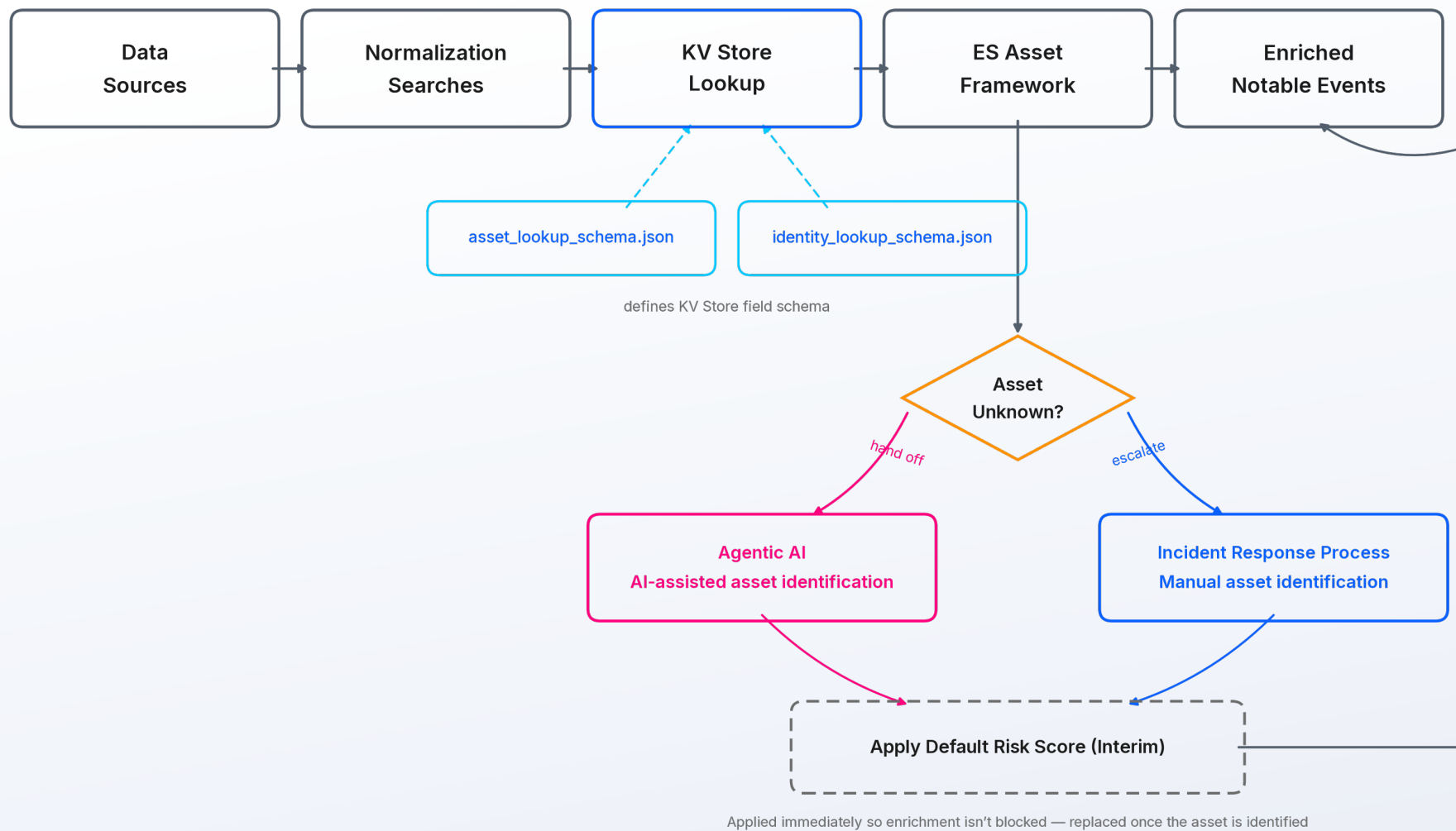
`` Enrich with Identity inventory (KV Store-backed lookup, refreshed every 15m) ``
| lookup identity_inventory_lookup identity_id
  OUTPUT identity_type, identity_owner,
  identity_status, identity_mfa_enrolled,
  identity_risk_sc
```

The Hard Part: Identity Correlation, Not Collection

```
| inputlookup asset_inventory_lookup
| eval asset_id=asset_id
| join type=left asset_id
  [ | inputlookup identity_inventory_lookup
    | rename primary_asset_id as asset_id ]
| eval last_correlated=strftime(now(),
"%Y-%m-%d %H:%M:%S")
| eval correlation_status=case(
  isnull(identity_id), "orphaned_asset",
  isnull(asset_id), "orphaned_identity",
  identity_status!="active",
  "stale_identity_on_active_asset",
  1=1, "correlated")
| table asset_id, asset_owner, asset_criticality,
  identity_id, identity_owner,
    identity_status,
    identity_mfa_enrolled,
    correlation_status,
    last_correlated
| outputlookup asset_identity_correlated_lookup
```



Architecture Walkthrough



Governance Gets Measurable (Takeaway 2)

All assets relevant to the secure operation of essential function(s) are identified and inventoried (at a suitable level of detail). **The inventory is kept up-to-date.**

You have prioritised your assets according to their importance to the operation of the essential function(s). **[Threat and Risk Scoring]**

You have assigned responsibility for managing all assets, including physical assets, relevant to the operation of the essential function(s). **[Process: Incident Management]**

Assets relevant to the essential function(s) are managed with cyber security in mind throughout their lifecycle, from creation through to eventual decommissioning or disposal. **[Process: Onboarding to Splunk]**



REDUCE RISK

Continuous visibility across the enterprise



IMPROVE SECURITY

Detect unknown assets and identity risks



ENSURE COMPLIANCE

Prove control and meet regulations



SPEED UP INCIDENT RESPONSE

Find what matters, when it matters



DRIVE OPERATIONAL EFFICIENCY

Eliminate blind spots and reduce noise

From Visibility to Automated Action (Takeaway 3)

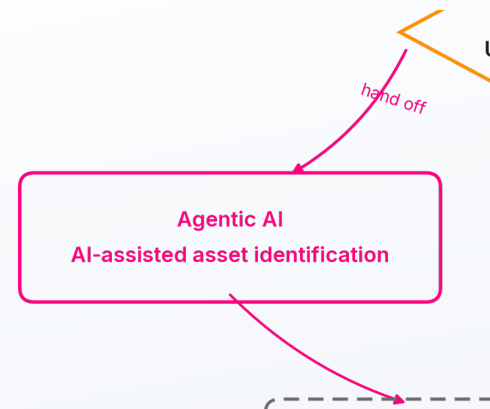
Deviation from compliance ‘fires’ an investigation

Keeping the Inventory up to date and investigates the discovered and the unknowns:

(Did you attend my talk yesterday?)

Alert Actions firing AI Agents:

- Perform a basic refresh of temporal assets
- Use a LLM to fingerprint and ID
- Rebalance risk scores dynamically before a human gets involved



... or fallback to your standard unknown on the wire incident process

The other AI: Assets and Identity. Using Splunk to keep in check

You don't need a CMDB: you need continuous, correlated identity.



Takeaway #1

Splunk is a consumer of A&I data, not 'the' source.

Once you have the business process and the feeds, you have observability and detection



Takeaway #2

Assets and Identity in ES once populated correctly evidences:

- CAF Principle A3 (Asset Management)
- NIST CSF ID.AM



Takeaway #3

Compliance Report is a live trigger, not a PDF

- Auditable KPIs of real time data, no longer using point in time spreadsheets
- Action an unknown or not see in X



The other AI: Assets and Identity. Using Splunk to keep in check

SEC1053

David Pollard
Unshakeable Salt Ltd, @UnshakeableSalt

Resources:
<https://github.com/UnshakeableSaltLtd/SplunkConf>

Thank you

